

Individuell inlämningsuppgift

Workshop 2 - MITRE ATT&CK och hotanalys

Syfte

Denna individuella inlämningsuppgift följer upp Workshop 2 och tränar förmågan att använda MITRE ATT&CK, TTP, defensiv hotanalys, attackkedjor, försvarsfrågor, källor, spårbarhet och koppling till projektarbete.

Viktig avgränsning

Uppgifterna ska användas för analys, dokumentation och försvar. Beskriv inte tekniska genomförandesteg för angrepp. Fokusera på vad ett säkerhetsteam behöver förstå, upptäcka, förhindra och följa upp.

Instruktion till studenten

- Uppgiften genomförs individuellt och lämnas in enligt lärarens instruktion i Canvas.
- Uppgiften täcker kursmål 1, 2, 6 och 11.
- Du får använda materialet från Workshop 2, MITRE ATT&CK, kursmaterial och egna anteckningar.
- Du får använda generativa AI-assistenter och AI-assisterade säkerhetsverktyg, dock ska du beskriva eventuell AI-användning och vad som kontrollerats manuellt.
- Fokusera på tydliga resonemang, spårbarhet och defensiv analys.
- Dina svar ska visa att du kan använda begreppen, inte bara återge definitioner.
- Om du är osäker: skriv vad du är osäker på och hur du skulle följa upp det.

Översikt

Del	Fokus	Uppgifter
Del 1	Förstå MITRE ATT&CK som analysramverk	1-4
Del 2	TTP: Tactic, Technique och Procedure	5-8
Del 3	Bygg en defensiv attackkedja	9-12
Del 4	Försvarsfrågor och Blue/Purple-perspektiv	13-16
Del 5	Källor, spårbarhet och kvalitet	17-20
Del 6	Koppling till backlog, sprint och Workshop 3	21-24

Del 1 - Förstå MITRE ATT&CK som analysramverk

Uppgift 1

Beskriv med egna ord vad MITRE ATT&CK används till i ett säkerhetsteam.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på analys, språk, struktur och försvarsperspektiv.

MITRE ATT&CK används för att strukturera och beskriva hur en angripare kan bete sig under ett angrepp. Ramverket delar upp olika beteenden i tactics och techniques, vilket gör det lättare för ett säkerhetsteam att förstå och prata om samma typ av hot.

En stor fördel är att teamet får ett gemensamt språk. I stället för att bara säga att någon exempelvis har genomfört phishing kan man koppla beteendet till en specifik teknik och se hur den passar in i en större attackkedja.

Ur ett försvarsperspektiv kan ATT&CK användas för att se vilka delar av en attack som organisationen kan upptäcka och var det finns brister i skyddet. Det kan också hjälpa teamet att prioritera vilka kontroller, loggar eller detektioner som behöver förbättras.

ATT&CK är däremot inte en färdig riskanalys. Bara för att en teknik finns i ramverket betyder det inte att den är relevant för alla organisationer. Man måste fortfarande bedöma vilka hot som faktiskt är relevanta för den egna verksamheten. MITRE ATT&CK är däremot ett bra underlag för en RSA.

Uppgift 2

Förklara varför ATT&CK inte ska användas som en checklista för att "göra attacker".

Svarsinstruktion: Skriv 150-250 ord. Beskriv skillnaden mellan analysramverk och angreppsinstruktion.

MITRE ATT&CK är tänkt som ett ramverk för att beskriva och analysera hur angripare beter sig, inte som en manual för hur man genomför en attack. Ramverket visar vilka mål en angripare kan ha och vilka tekniker som kan kopplas till dessa mål, men syftet är att skapa struktur och ett gemensamt språk i säkerhetsarbetet.

Ett säkerhetsteam kan till exempel använda ATT&CK för att förstå vilka delar av en attackkedja som är relevanta, vilka beteenden som behöver upptäckas och var organisationens försvar kan behöva förbättras.

Skillnaden mot en angreppsinstruktion är att ATT&CK beskriver beteenden på en övergripande nivå. Det är alltså inte tänkt att steg för steg visa hur ett angrepp ska genomföras.

För mig är därför ATT&CK främst ett analysverktyg. Det hjälper säkerhetsteam att förstå hot, dokumentera dem på ett enhetligt sätt och diskutera hur organisationen kan upptäcka eller minska risken för olika typer av angrepp.

Därför behöver ramverket alltid användas utifrån sammanhanget och vad man faktiskt vill analysera.

Uppgift 3

Välj fem tactics från Enterprise Matrix och beskriv vad varje tactic betyder på en övergripande nivå.

Svarsinstruktion: Använd egna ord. Undvik tekniska genomförandedetaljer.

Initial Access – Angriparen försöker komma in i organisationens system, till exempel genom phishing.

Execution – Angriparen försöker få något att köras i systemet för att kunna fortsätta attacken.

Credential Access – Angriparen försöker få tag på användarnamn, lösenord eller andra inloggningsuppgifter.

Discovery – Angriparen försöker ta reda på vilka användare, system och andra delar som finns i miljön.

Impact – Angriparen försöker påverka eller störa verksamheten, till exempel genom att göra system eller information otillgängliga.

Uppgift 4

Beskriv hur ATT&CK kan stödja kommunikationen mellan red team, blue team och ledning.

Svarsinstruktion: Skriv 200-300 ord. Ta upp gemensamt språk, spårbarhet och prioritering.

MITRE ATT&CK kan hjälpa red team, blue team och ledningen att prata om samma hot på ett tydligt sätt. Alla kan utgå från samma namn på olika tactics och techniques i stället för att beskriva samma sak på olika sätt.

Red team kan använda ATT&CK för att beskriva vilka typer av beteenden eller tekniker de har testat. Blue team kan sedan använda samma tekniknamn för att se vad de kan upptäcka och vilka skydd som behöver förbättras. Det gör det enklare att jämföra det red team testat med det blue team faktiskt kan upptäcka.

För ledningen kan ATT&CK göra det lättare att förstå vad säkerhetsteamet arbetar med. Ledningen behöver inte känna till alla tekniska detaljer, men kan få en tydligare bild av vilka delar av en attack som organisationen har bra skydd mot och var det finns brister.

ATT&CK gör också arbetet lättare att följa upp. Om en teknik har identifierats kan man dokumentera vad man har sett, vilka skydd som finns och vad som behöver förbättras. På så sätt blir det enklare att prioritera vilka säkerhetsåtgärder som är viktigast.

Kort sagt fungerar ATT&CK som ett gemensamt språk mellan de olika rollerna. Det gör också att beslut och prioriteringar blir lättare att förklara och följa upp senare.

Del 2 - TTP: Tactic, Technique och Procedure

Uppgift 5

Förklara skillnaden mellan tactic, technique och procedure.

Svarsinstruktion: Använd ett eget defensivt exempel. Håll dig på konceptuell nivå.

Tactic beskriver vad angriparen vill uppnå.

Technique beskriver hur angriparen försöker nå målet.

Procedure beskriver hur det faktiskt ser ut i det scenario man analyserar.

Exempel:

Tactic kan vara Initial Access, technique Spearphishing Link och procedure att ett falskt leverantörsmejl leder användaren till en falsk inloggningssida. Ur ett försvarsperspektiv kan man då titta på hur mejlet eller länken hade kunnat upptäckas.

Uppgift 6

Skapa en TTP-förklaring för tre valfria ATT&CK-tekniker.

Svarsinstruktion: För varje teknik: skriv tactic, technique och en kort procedure-beskrivning utan operativa instruktioner.

Tactic: Initial Access

Technique: Spearphishing Link, T1566.002

Procedure: Ett riktat phishingmejl innehåller en länk som används för att försöka få tillgång till ett användarkonto.

Tactic: Discovery

Technique: Account Discovery: Cloud Account, T1087.004

Procedure: Angriparen försöker ta reda på vilka användarkonton som finns i organisationens miljö.

Tactic: Collection

Technique: Email Collection: Email Forwarding Rule, T1114.003

Procedure: Angriparen försöker komma åt eller samla in information från användarens e-post.

Uppgift 7

Välj en tactic och identifiera tre tekniker som kan höra hemma inom den.

Svarsinstruktion: Motivera varför teknikerna passar in i tacticen.

Jag väljer Initial Access eftersom den handlar om hur angriparen försöker få en första väg in i organisationens miljö.

Tre tekniker som passar där är:

Phishing, T1566 – Angriparen försöker lura en användare genom till exempel mejl eller andra meddelanden.

Valid Accounts, T1078 – Angriparen använder ett konto som den fått tillgång till för att komma in i miljön.

External Remote Services, T1133 – Angriparen försöker ta sig in genom en tjänst som går att nå utifrån, till exempel en fjärranslutning.

De passar under Initial Access eftersom alla tre kan användas för att få den första åtkomsten till organisationens miljö..

Uppgift 8

Beskriv varför det kan vara svårt att mappa en observation till rätt teknik.

Svarsinstruktion: Ta upp osäkerhet, kontext, datakvalitet och behov av källor.

Det kan vara svårt att koppla en observation till rätt ATT&CK-teknik eftersom samma beteende ibland kan passa in på flera olika sätt.

Det beror mycket på vilken information man faktiskt har. Om loggar eller annan data är ofullständig kan det vara svårt att veta exakt vad som har hänt. Man kan då tolka samma observation på olika sätt.

Kontexten är också viktig. Ett beteende som verkar misstänkt i ett system kan vara helt normalt i ett annat. Därför behöver man förstå vad som hände före och efter observationen.

För att minska risken att välja fel teknik behöver man använda bra källor, till exempel MITRE ATT&CK, och jämföra beskrivningen av tekniken med det man faktiskt har sett.

Om man fortfarande är osäker tycker jag att det är bättre att skriva att mappningen är osäker än att låtsas vara helt säker.

Del 3 - Bygg en defensiv attackkedja

Uppgift 9

Bygg en enkel attackkedja med 3-5 steg.

Svarsinstruktion: Använd tactics som etiketter. Syftet är analys och försvar, inte teknisk genomförandeinstruktion.

Initial Access – Spearphishing Link, T1566.002

Ett phishingmejl som ser ut att komma från en leverantör skickas till användaren.

Initial Access – Valid Accounts: Cloud Accounts, T1078.004

Angriparen får tillgång till ett Microsoft 365-konto och kan använda det för att komma vidare.

Discovery – Account Discovery: Cloud Account, T1087.004
Angriparen försöker ta reda på vilka användare och konton som finns.
Collection – Data from Information Repositories: SharePoint, T1213.002
Angriparen letar efter information i SharePoint.
Collection – Email Forwarding Rule, T1114.003

En regel skapas för att vidarebefordra mejl och på så sätt komma åt information.

Uppgift 10

Beskriv varje steg i er kedja med “varför”, “hur” och “vad såg vi?”.

Svarsinstruktion: Koppla till TTP-modellen: tactic, technique och procedure.

Initial Access – Spearphishing Link
Varför: Angriparen vill få en första väg in.
Hur: Genom ett phishingmejl med en länk.
Vad såg vi: Ett mejl som ser ut att komma från en leverantör och leder vidare till en falsk inloggning.

Initial Access – Valid Accounts: Cloud Accounts
Varför: Angriparen vill kunna använda ett riktigt konto.
Hur: Genom att använda ett Microsoft 365-konto som angriparen fått tillgång till.
Vad såg vi: Kontot används för att komma vidare i miljön

Discovery – Account Discovery: Cloud Account
Varför: Angriparen vill förstå vilka konton och användare som finns.
Hur: Genom att kartlägga användare i molnmiljön.
Vad såg vi: Angriparen söker efter information om olika konton.

Collection – Data from Information Repositories: SharePoint
Varför: Angriparen vill hitta information som kan vara värdefull.
Hur: Genom att leta i SharePoint.
Vad såg vi: Sökningar efter dokument och information i SharePoint.

Collection – Email Forwarding Rule
Varför: Angriparen vill få tillgång till mer information över tid.
Hur: Genom att skapa en regel som vidarebefordrar mejl.
Vad såg vi: Mejlen skickas vidare automatiskt till en annan mottagare.

Uppgift 11

Identifiera vilka steg i attackkedjan som är mest osäkra.

Svarsinstruktion: Beskriv vad ni behöver veta mer om för att göra analysen bättre.

De två steg jag är mest osäker på är Valid Accounts: Cloud Accounts och Email Forwarding Rule.

När det gäller Valid Accounts: Cloud Accounts tycker jag det är svårt att veta om kontot verkligen är kapat bara för att någon har loggat in. Jag hade velat se mer information om var inloggningen kom ifrån, vilken enhet som användes och om det skiljer sig från hur användaren brukar logga in.

Email Forwarding Rule känns också lite osäkert eftersom en sådan regel faktiskt kan vara skapad av användaren själv. Där hade jag velat kontrollera när regeln skapades, vem som skapade den och vart mejlen skickades.

Så för mig är det främst de här två stegen som hade behövt mer underlag innan jag hade känt mig helt säker på analysen.

Uppgift 12

Rita eller beskriv attackkedjan som en enkel kedja från första kontakt till påverkan.

Svarsinstruktion: Använd pilar och korta rubriker. Om ni skriver digitalt kan ni använda tabell eller punktlista.

- Phishingmejl
- Kapat Microsoft 365-konto
- Kartläggning av konton
- Sökning i SharePoint
- Vidarebefordring av mejl

Påverkan blir att angriparen kan få fortsatt tillgång till information och mejl.

Del 4 - Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

Formulera minst en försvarsfråga per steg i attackkedjan.

Svarsinstruktion: Exempel: Hur skulle detta kunna upptäckas? Vilken signal, rutin eller kontroll kan vara relevant?

Spearphishing Link

Hur kan vi upptäcka eller stoppa phishingmejl innan användaren klickar på länken?

Valid Accounts: Cloud Accounts

Hur kan vi upptäcka om någon använder ett Microsoft 365-konto på ett sätt som inte är normalt?

Account Discovery: Cloud Account

Hur kan vi se om någon försöker kartlägga vilka användare och konton som finns?

Data from Information Repositories: SharePoint

Hur kan vi upptäcka om någon letar efter eller öppnar ovanligt mycket information i SharePoint?

Email Forwarding Rule

Hur kan vi upptäcka om en ny regel skapas för att vidarebefordra mejl till en ovanlig mottagare?

Uppgift 14

Välj två tekniker och resonera kring möjliga detektionssignaler.

Svarsinstruktion: Håll svaret på konceptuell nivå. Beskriv typer av signaler, inte tekniska exploit-steg.

Jag hade valt Spearphishing Link och Email Forwarding Rule.

Spearphishing Link

Här hade jag kollat efter saker som mejl från ovanliga avsändare, länkar som går till konstiga eller okända domäner och mejl som försöker stressa användaren att logga in snabbt. Om flera användare får liknande mejl samtidigt hade det också varit en tydlig varningssignal.

Email Forwarding Rule

Här hade jag framförallt tittat efter nya regler som skapas för vidarebefordring av mejl. Det hade också varit misstänkt om mejl plötsligt börjar skickas vidare till en extern adress som användaren normalt inte använder. Om regeln skapas nära inpå en ovanlig inloggning hade jag också sett det som en starkare signal.

Det viktiga är alltså inte en enskild signal, utan att flera saker tillsammans börjar se konstigt ut.

Uppgift 15

Välj två tekniker och resonera kring möjliga riskreducerande åtgärder.

Svarsinstruktion: Beskriv organisatoriska, tekniska eller processmässiga åtgärder.

Spearphishing Link

Här hade jag framförallt försökt minska risken genom bättre mejlfilter och blockering av misstänkta länkar. Men även utbildning är viktigt, så användare vet vad dom ska vara vaksamma på. MFA är också en bra åtgärd eftersom ett stulet lösenord då inte alltid räcker för att komma in.

Email Forwarding Rule

Här hade jag begränsat möjligheten att automatiskt vidarebefordra mejl till externa adresser om det inte finns ett behov av det. Man kan också ha övervakning på nya forwarding-regler, så att säkerhetsteamet får en varning om något ovanligt skapas. Det är även bra att regelbundet gå igenom vilka regler som finns och ta bort sådant som inte längre behövs.

Jag tycker det viktigaste är att man inte bara har en åtgärd, utan flera lager av skydd.

Uppgift 16

Beskriv hur ett säkerhetsteam kan använda en attackkedja för att förbättra sitt försvar.

Svarsinstruktion: Skriv 200-300 ord. Ta upp lärande, prioritering och uppföljning.

Jag tycker att attackkedjan passar bra med vårt Sprint Goal. Målet var bland annat att få en grundläggande förståelse för MITRE ATT&CK och hotanalys och vara redo att börja med den mer fördjupade analysen. Genom att vi nu har byggt en attackkedja och kopplat flera steg till MITRE ATT&CK tycker jag att vi har uppnått den delen av målet.

Sprintmålet behöver därför inte ändras i efterhand, men inför nästa sprint behöver vi gå vidare och kontrollera att våra mappningar stämmer och titta mer på hur attacken kan upptäckas och stoppas.

Generativ AI har använts som stöd för struktur och formulering. Jag har själv gått igenom svaren och kontrollerat relevanta begrepp, ATT&CK-mappningar och källor mot MITRE ATT&CK och kursmaterialet.

En attackkedja gör det lättare för säkerhetsteamet att se hela händelsen och inte bara en enskild del. Man kan se hur angriparen först tar sig in, vad som händer efter det och vart attacken till slut kan leda.

I vår kedja börjar det till exempel med phishing och går sedan vidare till ett kapat Microsoft 365-konto, kartläggning av användare och tillgång till information i SharePoint. Genom att titta på hela kedjan blir det enklare att se var man faktiskt hade kunnat stoppa attacken.

Det gör också att teamet kan prioritera bättre. Om man till exempel ser att phishing är ett stort problem kanske man behöver förbättra mejlfilter och utbildning. Om problemet istället är att ett kapat konto kan användas för länge utan att någon märker det så behöver man kanske lägga mer fokus på inloggningar och övervakning.

Attackkedjan kan även användas efteråt för att följa upp vad som fungerade och vad som inte gjorde det. Teamet lär sig också vilka delar av attacken som är svårast att upptäcka och kan ta med sig det till nästa analys. På så sätt kan säkerhetsteamet förbättra sina skydd över tid istället för att bara reagera när något redan har hänt.

För mig är den största fördelen att man får en bättre helhetsbild och lättare kan se var försvarat faktiskt behöver bli bättre. Det gör också arbetet tydligare för resten av teamet.

Del 5 - Källor, spårbarhet och kvalitet

Uppgift 17

Dokumentera vilka källor ni använder i er ATT&CK-analys.

Svarsinstruktion: Skriv minst tre källor eller länkar. Beskriv kort vad varje källa bidrar med.

MITRE ATT&CK Enterprise Matrix

<https://attack.mitre.org/matrices/enterprise/>

Jag använder den för att se vilka tactics och techniques som finns och hur dom hänger ihop.

MITRE ATT&CK Techniques

<https://attack.mitre.org/techniques/>

Här kontrollerar jag teknikernas namn, ID och beskrivningar så att jag inte mappar fel.

CISA – Best Practices for MITRE ATT&CK Mapping

<https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping>

Den använder jag som stöd för hur man kan göra en bra och tydlig ATT&CK-mappning och hur man bör dokumentera den.

Uppgift 18

Beskriv hur ni säkerställer att er TTP-mappning är rimlig.

Svarsinstruktion: Ta upp källa, motivering, osäkerhet och gruppgranskning.

För att säkerställa att vår TTP-mappning är rimlig jämför vi det vi har sett med MITRE ATT&CK och kontrollerar att tactic och technique faktiskt passar ihop.

Vi försöker också motivera varför vi har valt just den tekniken och inte bara välja något som verkar passa. Om vi är osäkra på en mappning skriver vi hellre det än att låtsas vara helt säkra.

Ett exempel är Valid Accounts: Cloud Accounts, eftersom den kan passa in på olika sätt beroende på vad som händer i attacken. Där behöver man därför titta på sammanhanget och inte bara teknikens namn.

Till sist tycker jag det är bra att någon annan i gruppen kollar igenom mappningen också. Då kan man upptäcka om någon teknik kanske passar bättre eller om något behöver ändras.

Uppgift 19

Skapa en mini-Definition of Done för en färdig hotanalys.

Svarsinstruktion: Lista minst fem kriterier. Kriterierna ska gå att använda av hela gruppen.

Attackkedjan är tydligt beskriven.

Tactic, technique och procedure är kopplade på ett rimligt sätt.

Källor finns med och går att kontrollera.

Osäkerheter är dokumenterade.

Det finns minst en försvarsfråga för varje steg.

Någon annan i gruppen har gått igenom analysen.

Det är tydligt vad som eventuellt behöver följas upp senare.

Uppgift 20

Beskriv vad som gör en hotanalys användbar för någon annan än den som skrev den.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på tydlighet, spårbarhet och mottagare.

För att en hotanalys ska vara användbar för någon annan än den som gjort den så måste den vara enkel att förstå och tydligt visa hur man har kommit fram till sina slutsatser.

Det ska till exempel gå att se vilka källor som har använts, varför en viss ATT&CK-teknik har valts och om det finns något i analysen som man fortfarande är osäker på. Då kan någon annan gå tillbaka och kontrollera informationen själv.

Jag tycker också att det är viktigt att anpassa analysen efter vem som ska läsa den. Ett säkerhetsteam kanske vill ha mer detaljer om tactics och techniques, medan en chef oftast behöver förstå vilken risk som finns och vad man borde prioritera.

En bra hotanalys ska också vara lätt att följa. Attackkedjan, försvarsfrågor och möjliga åtgärder behöver hänga ihop så att läsaren förstår vad som händer och varför det är viktigt.

För mig är en användbar hotanalys helt enkelt en analys som någon annan kan läsa, förstå och faktiskt använda utan att först behöva fråga personen som skrev den.

Del 6 - Koppling till backlog, sprint och Workshop 3

Uppgift 21

Uppdatera er backlog baserat på det ni upptäckte i Workshop 2.

Svarsinstruktion: Skriv minst fem nya eller ändrade backlog items. Ge kort motivering.

Identifiera relevanta informationskällor – ändrad till klar

Vi har nu använt MITRE ATT&CK och andra relevanta källor i analysen, därför kunde den stängas.

Förbereda Blue Team-perspektiv – ändrad till klar

Vi har tagit fram försvarsfrågor och tittat på hur attacken skulle kunna upptäckas, så den är också klar.

Koppla säkerhetsåtgärder till analysen – behöver fortsätta

Nästa steg blir att tydligare koppla säkerhetsåtgärder till varje del i attackkedjan.

Undersöka Threat Intelligence – behöver fortsätta

Vi behöver fortfarande titta mer på hur Threat Intelligence kan användas för att ge mer stöd till vår hotanalys.

Skapa visuell MITRE ATT&CK-mappning – behöver göras

En visuell mappning hade gjort attackkedjan enklare att förstå och även lättare att presentera.

Uppgift 22

Beskriv hur er attackkedja förhåller sig till ert Sprint Goal.

Svarsinstruktion: Är sprintmålet fortfarande relevant? Behöver något justeras?

Jag tycker att attackkedjan passar bra med vårt Sprint Goal. Målet var bland annat att få en grundläggande förståelse för MITRE ATT&CK och hotanalys och vara redo att börja med den mer fördjupade analysen.

Genom att vi nu har byggt en attackkedja och kopplat flera steg till MITRE ATT&CK tycker jag att vi har uppnått den delen av målet.

Sprintmålet behöver därför inte ändras i efterhand, men inför nästa sprint behöver vi gå vidare och kontrollera att våra mappningar stämmer och titta mer på hur attacken kan upptäckas och stoppas.

Uppgift 23

Formulera minst två uppföljningsfrågor inför Workshop 3.

Svarsinstruktion: Frågorna ska kunna användas vid review eller retrospektiv.

Är vår ATT&CK-mappning rätt eller finns det någon teknik vi borde ändra?

Vilka delar av vår attackkedja behöver vi jobba mer med innan vi kan säga att analysen är klar?

Vad fungerade bra i gruppen och vad kan vi göra bättre i nästa sprint?

Uppgift 24

Förbered en kort statusrapport till Workshop 3.

Svarsinstruktion: Skriv 5-7 punkter: vad ni gjorde, vad som blev klart, vad som är oklart och vad ni vill ändra.

Vi har byggt en attackkedja och kopplat stegen till MITRE ATT&CK.

Vi har gått igenom tactics, techniques och procedures och försökt få mappningen så tydlig som möjligt.

Identifiera relevanta informationskällor och Förbereda Blue Team-perspektiv är klara i vår backlog.

Vi är fortfarande lite osäkra på om alla ATT&CK-mappningar är helt rätt och vill därför kontrollera dom en gång till.

Threat Intelligence och kopplingen mellan säkerhetsåtgärder och attackkedjan behöver vi jobba vidare med. Vi vill även göra en visuell MITRE ATT&CK-mappning så att analysen blir enklare att förstå och presentera. Inför nästa sprint vill vi lägga mer fokus på försvar, detektion och vad som faktiskt går att förbättra.

AI-användning:

Jag använde Claude som stöd för struktur och formulering av vissa svar. Jag kontrollerade själv begrepp, ATT&CK-mappningar och källor mot MITRE ATT&CK och kursmaterialet. Jag anpassade sedan svaren efter vårt eget arbete från Workshop 2 och 3 och gjorde egna bedömningar kring bland annat attackkedjan, osäkerheter, försvarsfrågor och backloggen.

Frivillig fördjupningsutmaning

Skapa en komplett mini-hotanalys baserad på din Workshop 2-kedja.

Inkludera: mål med analysen, attackkedja, TTP-tabell, försvarsfrågor, källor, osäkerheter, uppdaterad backlog och förslag till nästa sprint. Max tre sidor.

Rekommenderade referenser

- MITRE ATT&CK: <https://attack.mitre.org/>
- MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/matrices/enterprise/>
- CISA - Best Practices for MITRE ATT&CK Mapping: <https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping>
- MITRE ATT&CK Data & Tools: <https://attack.mitre.org/resources/attack-data-and-tools/>

Bedömningskriterier

Bedömningen fokuserar på analysförmåga, begreppsanvändning, spårbarhet, defensivt perspektiv och koppling till projektarbete.

Matrisen är formulerad med kursens nivåer Godkänt (G) och Väl godkänt (VG). Den mellersta kolumnen beskriver kvaliteter som stärker bedömningen inom godkänd nivå och kan användas som stöd i återkoppling.

Bedömningsområde	Grundläggande krav för G	Tydliga kvalitetskännetecken	Kvalitetskännetecken för VG
Förståelse för MITRE ATT&CK	Kan beskriva ATT&CK på en grundläggande nivå och visar förståelse för ramverkets syfte.	Förklarar ATT&CK med egna ord och kopplar ramverket till hotanalys och säkerhetsarbete.	Visar fördjupad förståelse för ATT&CK som analysramverk och resonerar kring styrkor, begränsningar och användningsområden.
TTP-förståelse	Kan identifiera tactic, technique och procedure samt beskriva skillnaden översiktligt.	Använder TTP-begreppen konsekvent och förklarar sambanden mellan dem.	Använder TTP som ett naturligt analysverktyg och kan motivera val samt alternativa tolkningar.
Attackkedjor	Har skapat en enkel attackkedja där stegen följer en logisk ordning.	Attackkedjan är väl motiverad och sambanden mellan stegen förklaras.	Analysen visar systemsyn och används för att resonera kring risker och försvarsperspektiv.
Försvarsfrågor	Har formulerat relevanta försvarsfrågor.	Försvarsfrågorna är välformulerade och kopplas till upptäckt, begränsning eller uppföljning.	Kopplar angriparbeteenden till flera möjliga försvarsperspektiv och resonerar kring prioritering.
Källor och spårbarhet	Anger källor och referenser till analysunderlaget.	Motiverar hur källorna används och visar förståelse för spårbarhet.	Reflekterar kring källornas styrkor och begränsningar och håller hög dokumentationskvalitet.
Projektarbete	Har uppdaterat backlog eller projektunderlag.	Kopplar analysen till Sprint Goal, backlog eller Definition of Done.	Visar hur analysen skapar värde i projektet och resonerar kring prioritering, risk och nästa steg.

Samlad bedömning

Godkänt (G)

Studenten har genomfört huvuddelen av uppgifterna, visar grundläggande förståelse för ATT&CK, kan beskriva en enkel attackkedja, kan formulera relevanta försvarsfrågor och kan dokumentera sitt arbete.

Väl Godkänt (VG)

Studenten visar god analytisk förmåga, använder ATT&CK och TTP konsekvent, motiverar sina slutsatser, identifierar osäkerheter, visar god förståelse för försvarsperspektivet och kopplar analysen till projektets mål och arbetssätt.